



INCIDENT RESPONSE

Incident Response Plan

Lightweight IR plan for a founder-led startup. Founders handle all incidents directly. Customer notification within 72 hours.

This plan is aligned with NIST SP 800-61r2 and defines how Masar Zero founders respond to security incidents. It includes customer and subprocessor notification commitments. There is no dedicated IR team or 24x7 SOC; founders handle all incidents directly.

PREPARED BY	Masar Zero W.L.L.
DOCUMENT ID	MZ-POL-007
VERSION	v1.0
EFFECTIVE	12 July 2026
CLASSIFICATION	Confidential — Authorized Recipients Only

Document Control

Document ID	MZ-POL-007	Version	v1.0
Effective Date	12 July 2026	Review Cycle	Annual (next review: July 2027)
Document Owner	Dr. A. Latif Alkhaja	Classification	Confidential
Publisher	Masar Zero W.L.L.	Contact	hari@masarzero.com

Revision History

Version	Date	Author	Summary of Change
v1.0	12 July 2026	Masar Zero	Initial release of Incident Response Plan.

Approval

This document is prepared by Hari Krishna and approved by Dr. A. Latif Alkhaja, Chairman of Masar Zero W.L.L. It is effective as of the date shown above and is reviewed annually or upon significant change per MZ-POL-001 §7. Distribution is restricted to authorized recipients; redistribution requires written approval from Masar Zero leadership.

Role	Name	Signature	Date
Prepared by	Hari Krishna		
Approved by	Dr. A. Latif Alkhaja (Chairman)		

1. Purpose & Scope

This Incident Response Plan (IR Plan) defines the process Masar Zero W.L.L. follows when responding to security incidents. It is aligned with NIST SP 800-61r2. The plan is owned and operated by Masar Zero founders; there is no dedicated IR team.

Honest scope statement. Masar Zero is a small founder-led startup. There is no dedicated incident response team, no 24x7 SOC, and no formal on-call rotation. Founders handle all incidents directly during business hours. For incidents affecting customer station operations outside business hours, founders are reachable via the customer notification contacts in §5.

2. Incident Severity Classification

Incidents are classified into three severity levels based on operational impact and data sensitivity.

Severity	Definition	Examples	Founder Response
P1 — Critical	Severe operational impact OR confirmed data breach.	VRU unavailable; WeCon box compromised; founder credentials leaked; subprocessor breach confirmed affecting Masar Zero data.	All founders notified within 1 hour; incident commander designated.
P2 — High	Significant operational impact OR suspected data breach.	Dashboard unavailable >4 hours; suspected unauthorized access; subprocessor security incident notification received.	Founders notified within 4 hours.
P3 — Medium/Low	Limited impact; contained.	Single user account locked; isolated malware on founder laptop; non-critical bug.	Founder reviews next business day.

Table 1 — Incident severity classification matrix.

3. Incident Response Lifecycle

Masar Zero follows the four-phase NIST SP 800-61r2 incident response lifecycle in a lightweight form appropriate to a small startup.

3.1 Preparation

Preparation activities: (a) maintain this IR Plan and review it annually; (b) maintain founder contact details (phone, email) in a Google Sheet accessible to all founders; (c) maintain subprocessor emergency contact details (security@emails) in 1Password; (d) ensure founder laptops are patched and encrypted.

3.2 Detection & Analysis

Detection occurs through subprocessor alerts (email to founders) or founder observation. If a founder identifies a potential incident, they notify the other founders via the founder chat channel. Founders collectively assess whether the alert is a false positive or a genuine incident. If genuine, founders designate an incident commander (default: the

founder who detected the incident).

3.3 Containment, Eradication & Recovery

Containment actions may include: (a) suspending WorkOS accounts; (b) revoking Vercel deployment access; (c) rotating subprocessor API keys; (d) powering off the WeCon box at the station (only for P1, only with founder agreement and customer notification). Eradication removes the cause (e.g., deploy patch, remove malicious code, rotate credentials). Recovery restores normal operation and verifies the incident is resolved.

3.4 Post-Incident Activity

Within 10 business days of incident closure, the incident commander produces a brief post-incident report (a Google Doc) covering: (a) timeline of events; (b) root cause analysis; (c) impact assessment; (d) response effectiveness; (e) lessons learned; (f) corrective actions with owners and target dates. The report is reviewed by all founders.

4. Internal Escalation

Internal escalation timelines: (a) P1 — all founders notified within 1 hour; (b) P2 — founders notified within 4 hours; (c) P3 — founders review next business day. There is no 24x7 on-call rotation.

5. External Reporting — Customer & Other Parties

Masar Zero commits to the following external notification timelines:

Recipient	Trigger	Timeline	Method
Customer — Vendor Risk Mgmt	Any P1 or P2 incident affecting VRU operations or Masar Zero data.	Within 72 hours of confirmation	Email to customer VRM contact + phone (per service agreement)
Customer — Site Operations	Any incident affecting VRU availability.	Within 4 hours of confirmation	Phone to site operations (per service agreement)
Affected Masar Zero operators	Personal data breach affecting their account.	Without undue delay (target: 72 hours)	Email + mandatory password reset
Supervisory authority (GDPR Art. 33)	Personal data breach (operators only).	Within 72 hours of awareness	Submitted to lead authority via online portal
Subprocessors (WorkOS / Vercel / Supabase / WeCon)	Incident affecting their service or data.	Within 1 hour of confirmation	Email to subprocessor security contact

Table 2 — External notification matrix.

Customer notification commitment. Masar Zero commits to notifying the customer Vendor Risk Management function within 72 hours of confirming any P1 or P2 incident that affects VRU operations or Masar Zero data. For incidents affecting VRU availability at the site, Masar Zero notifies site operations within 4 hours by phone. Specific notification terms per customer are defined in the applicable service agreement; the 72-hour and 4-hour timelines above are Masar Zero standard commitments.

6. Subprocessor Incident Coordination

Each subprocessor (WorkOS, Vercel, Supabase, WeCon, Google Workspace, GitHub, 1Password) is contracted to notify Masar Zero of incidents affecting Masar Zero data within 24 hours of subprocessor awareness. On receipt of such a notification, founders: (a) assess impact on Masar Zero data and operations; (b) coordinate with the subprocessor on remediation; (c) escalate to P1 if Masar Zero data was confirmed exposed; (d) document the incident in the post-incident report.

7. Communication Protocol

During an active incident, communication follows these principles: (a) the incident commander is the single point of contact for external communication; (b) no Masar Zero founder communicates with external parties (including the customer, media, or affected individuals) without incident commander approval; (c) all incident communication is logged in a Google Doc for post-incident review.

8. Plan Review

This IR Plan is reviewed annually by founders and updated based on lessons learned from any incidents or subprocessor notifications during the year.

9. References

- BAPCO-QR-001 — Master Questionnaire Response §7.10
- MZ-POL-001 — Governance Program
- MZ-POL-004 — Continuous Monitoring & Log Management (detection)
- MZ-POL-012 — Business Continuity & Disaster Recovery Plan
- NIST SP 800-61r2 — Computer Security Incident Handling Guide
- GDPR Article 33 — Notification of personal data breach to supervisory authority

MZ-POL-007 — Incident Response Plan. End of document.